



GUÍA TÉCNICA // DEFENSA EN PROFUNDIDAD

La Estrategia de Defensa en Profundidad

La seguridad no es una herramienta, es un proceso de capas. Tratamos al sistema operativo como una fortaleza que debe ser asegurada desde el perímetro hasta el núcleo.

```
$ ufw status verbose
```

```
$ sudo rkhunter --check --sk
```

```
$ aide --check  
$ clanscan -r /home
```

```
$ sudo lynis audit system  
# flags. / scripts
```



El Perímetro: Control de Tráfico con UFW

Theory

UFW (Uncomplicated Firewall) es la interfaz de Netfilter. Su función es bloquear conexiones no deseadas. Es vital tanto para servidores como para escritorio.

La Regla de Oro: Denegar todo por defecto. Si no está invitado, no entra.

Practice

```
$ sudo ufw enable
(Output) Firewall is active and enabled on system startup

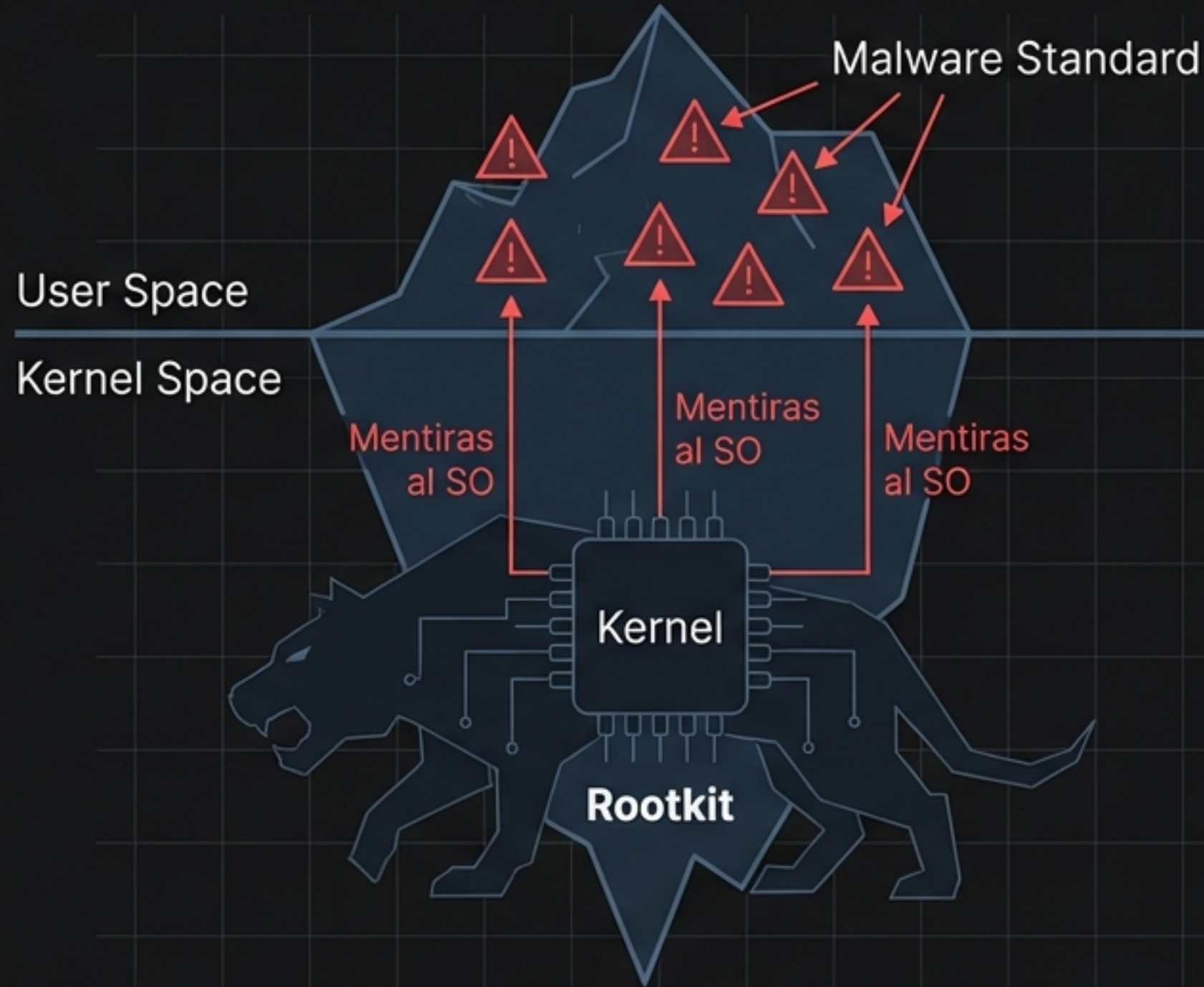
$ sudo ufw default deny incoming
(Output) Default incoming policy changed to 'deny'

$ sudo ufw allow ssh
(Output) Rule added

$ sudo ufw status verbose
(Output) Status: active...
        Default: deny (incoming)...
```


Anatomía de un Rootkit: El Enemigo Invisible

Definición: Root (Privilegio) + Kit (Herramientas). No buscan dañar, buscan ocultar.



El Mecanismo:

1. El Engaño: Modifican `ls`, `ps`, `netstat`.

```
$ ls -la /rootkit_files  
(No files found)
```

2. **Inyección en Kernel:** Se alojan en el núcleo, controlando la memoria y la red.

Peligro: Acceso persistente y evasión de antivirus tradicionales.

Cazadores de Amenazas: rkhunter y Chkrootkit

Herramientas que escanean el sistema buscando anomalías y firmas.



rkhunter

Rootkit Hunter. Basa su análisis en bases de datos de firmas y hashes de archivos.

```
$ sudo apt install rkhunter  
$ sudo rkhunter --check
```



Chkrootkit

Check Rootkit. Una alternativa más ligera y rápida para escaneos frecuentes.

```
$ sudo apt install chkrootkit  
$ sudo chkrootkit
```

Insight: Ambas herramientas buscan 'mentiras' en el sistema, pero requieren interpretación humana para filtrar falsos positivos.

Gestión de Falsos Positivos en rkhunter (I)

Caso 1: La advertencia de lwp-request

Warning: Binary expected,
script found

Archivo: /etc/rkhunter.conf.local

SCRIPTWHITELIST=/usr/bin/lwp-request

rkhunter espera un binario, pero en Debian es un script Perl. Es seguro.

Caso 2: Cambios en /etc/passwd y /etc/group

Warning: File properties
changed

\$ sudo rkhunter --propupd

i Actualiza la base de
datos de propiedades.

Ocurre tras crear usuarios o
actualizaciones. Los hashes no coinciden.

Gestión de Falsos Positivos en rkhunter (II): Archivos Ocultos

Alerta común: "Checking for hidden files and directories [Warning]". No adivines, investiga.

```
$ sudo grep -E 'Found|Hidden' /var/log/rkhunter.log
Found hidden file: /etc/.updated
Found hidden file: /dev/.udev
```

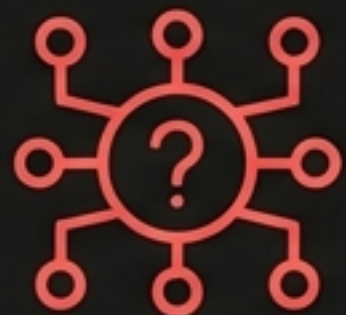
Archivos Benignos Comunes

- /etc/.updated (Marcador de APT)
- /dev/.udev (Servicio del sistema)
- /etc/.resolv.conf.systemd-resolved.bak (Backup DNS)

Solución: Añadir a la lista blanca.

```
ALLOWHIDDENFILE=/etc/.updated
```

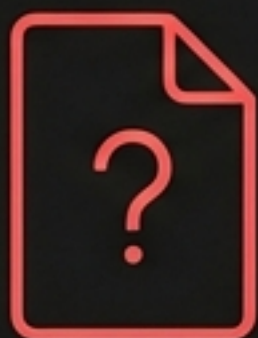

Interpretando Alertas de Chkrootkit



Alerta: PACKET SNIFFER

Reporta que NetworkManager está escuchando tráfico.

Realidad: Es el comportamiento estándar de NetworkManager (especialmente en VMs y Wi-Fi). **No requiere acción.**



Alerta: Suspicious files (.document / .build-id)

Reporta archivos ocultos en rutas de Ruby, LibreOffice o Kernel.

Realidad: Son marcadores de paquetes o cachés legítimos.

Chkrootkit es agresivo con los archivos punto (hidden files). Verifique la ruta.

Integridad de Archivos: La "Foto" del Sistema con AIDE

Advanced Intrusion Detection Environment



Instalar

```
apt install aide
```



Inicializar

```
aide --init
```

(Crea la línea base)



Activar

```
mv aide.db.new aide.db
```



Auditar

```
aide --check
```

⚠ Pro Tip

Nota: La inicialización puede tardar. Es vital ejecutarlo en un sistema limpio recién instalado.

Higiene Digital: Antivirus con ClamAV

Linux rara vez se infecta con virus clásicos, pero puede portarlos. ClamAV es vital si compartes archivos con Windows o gestionas servidores de correo.



```
$ sudo apt install clamav clamav-daemon

# Actualizar base de datos de firmas
$ sudo freshclam
ClamAV update process started...

# Escanear directorio recursivamente
$ clamscan -r /home
```

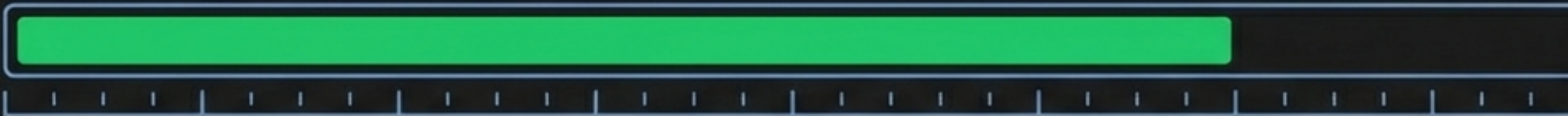

Auditoría y Hardening Proactivo

Lynis (El Auditor)

Escanea el sistema, kernel y configuración para otorgar una puntuación de seguridad y una lista de tareas.

Hardening Index: 78/100

78/100



Automatización (Ansible & Scripts)

Uso de roles (CIS, STIG) para aplicar reglas masivamente.



⚠️ ADVERTENCIA CRÍTICA: Revisar siempre el código. Nunca ejecutar scripts de GitHub a ciegas; pueden romper el sistema.

Mejores Prácticas: La Base de la Seguridad



Actualizaciones

```
apt update && apt upgrade
```

La medida más efectiva
contra vulnerabilidades.



Superficie de Ataque

Deshabilitar servicios
innecesarios. Menos
código = menos riesgos.



Control de Acceso

Contraseñas robustas y
2FA en SSH obligatorio.



Mentalidad

La seguridad no es un
estado final, es
mantenimiento continuo.

Resumen: Tu Checklist de Seguridad

- ☐ **Perímetro:** Firewall `UFW` activado con '`Default Deny`'.
- ☐ **Detección:** Rkhunter instalado y Whitelists configuradas.
- ☐ **Integridad:** Base de datos AIDE inicializada en sistema limpio.
- ☐ **Higiene:** Escaneos regulares con ClamAV configurados.
- ☐ **Auditoría:** Ejecución de Lynis para identificar brechas restantes.



Una fortaleza digital se construye capa a capa.